

Cirque Corporation

Supplier Relationships Policy

Document ID: IS-CIRQ-P-013-G

Category: Related to Outsourcing

Division: Policy

Type: Global

Version: 1.0

Effective Date: 2025-07-01

Review Date: 2026-07-01

Approved By: Executive Committee

Generated: March 02, 2026

1. Purpose

The purpose of this policy is to establish Cirque's requirements for managing information security risks associated with supplier relationships. This includes ensuring that the security of Cirque's information and information systems is protected when suppliers have access to them, or when Cirque's processes are outsourced to suppliers. This policy aligns with ISO/IEC 27001:2022 Annex A.15, ensuring consistent information security controls across the supply chain.

2. Scope

2. Scope

This policy applies to all Cirque personnel (employees, contractors) involved in selecting, engaging, managing, and terminating relationships with suppliers who:

- Have access to Cirque's information, information systems, or facilities.

- Process, store, or transmit Cirque's information on its behalf.
- Provide IT products, components, or services that are critical to Cirque's information systems or business operations.

This includes, but is not limited to, cloud service providers (e.g., Microsoft 365, Azure), software vendors (e.g., Omnify, Cadence, GitLab, Asana, QuickBooks), IT service providers, and any other third party with a significant impact on Cirque's information security.

****3. Principles of Supplier Relationship Security****

3. Principles of Supplier Relationship Security

Cirque manages supplier relationships with information security in mind, based on the following principles:

- ****Risk-Based Approach:**** Supplier relationships shall be managed based on the level of information security risk they pose to Cirque.
- ****Due Diligence:**** Appropriate due diligence shall be performed on potential suppliers before engagement.
- ****Contractual Obligations:**** Information security requirements shall be clearly defined and legally enforced through contractual agreements.
- ****Monitoring and Review:**** Supplier compliance with information security requirements shall be regularly monitored and reviewed.
- ****Lifecycle Management:**** Information security shall be considered throughout the entire supplier relationship lifecycle, from selection to termination.

****4. Requirements for Supplier Relationship Security****

4. Requirements for Supplier Relationship Security

****4.1. Supplier Selection and Assessment:**** a. Before engaging a new supplier, especially those with access to sensitive information or critical systems, a comprehensive security assessment shall be conducted to evaluate their information security posture. b. The level of assessment shall be proportionate to the risk posed by the supplier and the sensitivity of the information involved. This assessment is detailed in IS-CIRQ-PR-019-G: Supplier Security Review Procedure. c. Due diligence may include, but is not limited to, reviewing security certifications (e.g., ISO 27001, SOC 2), security policies, incident response plans, and conducting security questionnaires or audits.

****4.2. Contractual Agreements:**** a. All contracts with suppliers handling Cirque's information or providing critical services shall include explicit information security clauses. b. These clauses shall cover, at minimum: * Confidentiality and data protection requirements. * Roles and responsibilities for information security. * Compliance with applicable laws and regulations (e.g., data privacy laws). * Incident management and reporting obligations. * Right to audit clauses (where appropriate). * Security breach notification requirements. * Data retention and disposal requirements upon contract termination. * Requirements for subcontracting (if applicable). c. Legal review of such contracts is mandatory.

****4.3. Information Sharing and Access Control:**** a. Information shared with suppliers shall be limited to the minimum necessary for the fulfillment of the contract (principle of least privilege). b. Access to Cirque's information systems and facilities granted to suppliers shall be strictly controlled and monitored, with access rights provisioned and de-provisioned promptly. c. Remote access by suppliers shall be secured using strong cryptographic controls (e.g., VPNs with MFA) as per

****4.4. Monitoring and Review of Supplier Performance:**** a. Cirque shall regularly monitor and review suppliers' adherence to contractual information security requirements. b. The frequency and depth of monitoring shall be based on the risk level of the supplier and the criticality of the services or data they handle. c. Monitoring activities may include: * Review of supplier's security reports or audit results. * Periodic security questionnaires. * Performance reviews with security as a key metric. * Audits or inspections by Cirque (where contractually permitted).

****4.5. Managing Changes to Supplier Services:**** a. Any significant changes to the services provided by a supplier, or to their security controls, shall be communicated to and reviewed by Cirque to assess potential information security impacts. b. Changes impacting Cirque's information security shall be managed through the IS-CIRQ-PR-013-G: Change Management Procedure.

****4.6. Termination of Supplier Relationships:**** a. Upon termination or expiration of a supplier contract, Cirque shall ensure that: * All access rights to Cirque's information systems and facilities are immediately revoked. * All Cirque's information held by the supplier is securely returned, destroyed, or transferred, in accordance with contractual agreements and IS-CIRQ-PR-007-G: Asset Classification and Handling Procedure. * Confirmation of secure data destruction is obtained from the supplier.

****5. Responsibilities****

5. Responsibilities

- ****IT Manager:**** Overall responsible for the implementation and oversight of this policy. Manages the process for assessing,

contracting, and monitoring suppliers from an information security perspective.

- **Procurement Department:** Responsible for ensuring that information security requirements and clauses are included in all relevant supplier contracts.
- **Legal Counsel:** Reviews all supplier contracts to ensure legal enforceability of security clauses.
- **Department Managers/Service Owners:** Responsible for identifying and managing suppliers relevant to their operations and ensuring their teams comply with this policy.

****6. Related Documents****

6. Related Documents

- IS-CIRQ-PR-019-G: Supplier Security Review Procedure (To be drafted next)
- IS-CIRQ-P-001-G: Information Security Policy
- IS-CIRQ-P-007-G: Asset Management Policy
- IS-CIRQ-PR-007-G: Asset Classification and Handling Procedure
- IS-CIRQ-P-008-G: Access Control Policy
- IS-CIRQ-P-009-G: Cryptography Policy
- IS-CIRQ-PR-013-G: Change Management Procedure

****7. Policy Review****

7. Policy Review

This policy will be reviewed at least annually, or sooner if there are

significant changes to Cirque's supplier relationships, business operations, or relevant legal/regulatory requirements.